

Web-Security und Intrusion Prevention

SoSe 26

Prof. R. Zahoransky

Hochschule Furtwangen (University of Applied Science)

Aufgabenblatt 5 Cross Site Scripting (XSS)

Lernziele: Broken Access Schwachstellen aufzeigen und verhindern

Abgabetermin wird bekannt gegeben

Aufgabe 1: Verstehen der Webanwendung

Die Anwendung ist ein in Python geschriebenes Gästebuch, dass Flask verwendet.

- Starten Sie die Anwendung mit `docker compose up`.
- Öffnen Sie den Browser und navigieren Sie zu <http://127.0.0.1:5000>
- Das Passwort lautet „password123“.
- Testen Sie, ob Sie einen Eintrag machen können

Aufgabe 2: Testen Sie, ob die Webseite angreifbar ist

In der Vorlesung haben Sie verschiedene Möglichkeiten gesehen, ein „Alert“-Fenster in Javascript zu erzeugen.

- Versuchen Sie Javascript Code einzutragen, dass ein Fenster anzeigt
- Zeigen Sie: Wo haben Sie den Code eingefügt?
- Was haben Sie eingefügt?
- Zeigen Sie ein Screenshot

Aufgabe 3: Stehlen Sie ein Cookie

Sie möchten nun das geheime Cookie stehlen, das bei der Anmeldung an den Browser übertragen wird. Mit Javascript können Sie einen Browser auf eine andere Webseite navigieren. Hierbei ist es auch möglich GET-Parameter mitzugeben. Was Sie als Angreifer(in) benötigen, ist ein Webserver, der die GET-Parameter entgegennimmt.

- Python gibt Ihnen die Möglichkeit schnell einen Webserver zu starten. Der Aufruf lautet:
`python3 -m http.server <port>`
- Starten Sie einen Webserver auf Port 8000
- Fügen Sie in das Gästebuch ein Javascript ein, welches die Browser Ihres Opfers auf Ihren Webserver leitet. Dabei sollen die Cookies als GET-Parameter weitergeleitet werden
- Nutzen Sie die Vorlesungsfolien oder suchen Sie im Internet nach einer solchen Möglichkeit

Dokumentieren Sie die Ausgabe Ihres Webservers, aus welcher das geheime Cookie ersichtlich ist.

Aufgabe 4: Nutzen Sie das gestohlene Cookie

Sie haben nun zwar nicht das Passwort für den Login erhalten, aber das Cookie, den legitimen Benutzern erhalten. In der Realität würde dies einer Sitzungs-ID entsprechen, die bei jedem Aufruf vom Browser übertragen wird. Hierdurch erkennt die Webanwendung, dass der Benutzer bereits

eingeloggt (authentifiziert) ist. Versuchen Sie das Cookie zu benutzen, sodass Sie die Login-Seite umgehen können.

- Um einen Gästebucheintrag zu erzeugen, muss ein POST-Request mit den Variablen „name“ und „message“ an 127.0.0.1:5000 gesandt werden. Im Folgenden sehen Sie ein Beispiel für einen POST-Aufruf des Gästebuchs:

```
POST / HTTP/1.1
Host: 192.168.1.167:5000
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101
Firefox/150.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: de,en-US;q=0.9,en;q=0.8
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 36
Origin: http://192.168.1.167:5000
DNT: 1
Sec-GPC: 1
Connection: keep-alive
Referer: http://192.168.1.167:5000/
Cookie: secretcookie=itsasecret
Upgrade-Insecure-Requests: 1
Priority: u=0, i

name=Ein+Name&message=Eine+Nachricht
```

- Erstellen Sie einen Aufruf mit curl, der erfolgreich einen Eintrag mit dem gestohlenen Cookie erstellt
- Dokumentieren und zeigen Sie den Aufruf

Aufgabe 5: Sichern Sie die Anwendung ab (Schritt 1)

Verhindern Sie, dass JavaScript Zugriff auf die Cookies hat:

In der Anwendung app.py existiert die Methode login(). Mit resp.set_cookie wird das Cookie erstellt. Erweitern Sie den set_cookie Aufruf so, dass die Variablen httponly auf True gesetzt ist. Damit verhindern Sie, dass JavaScript Zugriff auf das Cookie hat.

- Zeigen Sie die Zeile mit dem korrigierten Aufruf von set_cookie.
- Um die Wirksamkeit zu testen, müssen Sie sich erst aus dem Gästebuch aus- und wieder einloggen. Erst dann wird das Cookie mit der neuen Eigenschaft auf den Browser übertragen!

Aufgabe 6: Sichern Sie die Anwendung ab (Schritt 2)

Verhindern Sie XSS

- Filtern Sie nach schadhaften Zeichen wie „<“, „>“, „script“, ...
- Oder: Prüfen Sie das Template „index.html“. Aktivieren Sie das automatische Filtern von Benutzereingaben
- Stoppen Sie den laufenden Container mit docker compose down
- Löschen Sie den Container mit docker system prune
- Starten Sie den Container erneut mit docker compose up
- Zeigen Sie, dass nun kein XSS mehr möglich ist